
MINI-PROJET D'AUDIT SI

Audit du Système d'Information

Analyse théorique — Périmètre, Risques, Vulnérabilités et Recommandations

ESAIP École d'Ingénieurs | IR, MSC
Sécurité des Réseaux et Sécurité des Systèmes
Costantin Josué LOCOSSA

1. Description du Contexte et des Enjeux

1.1 Présentation de l'Université F

L'Université F est un établissement d'enseignement supérieur comptant 12 500 étudiants et 850 personnels répartis sur 4 sites géographiques interconnectés. Sa Direction des Systèmes d'Information (DSI) assure la gestion d'une infrastructure hybride combinant un datacenter on-premise et une extension cloud public.

1.2 Mission de la DSI

- Gestion des infrastructures informatiques on-premise et cloud
- Maintien en condition opérationnelle des services numériques
- Sécurisation des données et des accès
- Accompagnement numérique des étudiants, enseignants et personnels administratifs
- Support des plateformes pédagogiques, administratives et de recherche

1.3 Enjeux Stratégiques

La DSI opère dans un contexte de modernisation progressive. Cette transition hybride génère une complexité accrue en matière de sécurité, notamment en raison de la coexistence de systèmes anciens (on-premise) et de nouveaux services cloud. Les principaux enjeux sont :

- Disponibilité des services critiques (Moodle, ENT, portail étudiant) particulièrement durant les périodes d'examens
- Protection des données personnelles des étudiants et du personnel (conformité RGPD)
- Sécurisation des données sensibles de recherche (propriété intellectuelle, brevets)
- Gestion d'une population étudiante nombreuse représentant un risque humain élevé
- Maîtrise d'une architecture techniquement hétérogène (Windows, Linux, IoT, cloud)
- Contraintes budgétaires limitant les investissements en sécurité

1.4 Synthèse du Système d'Information

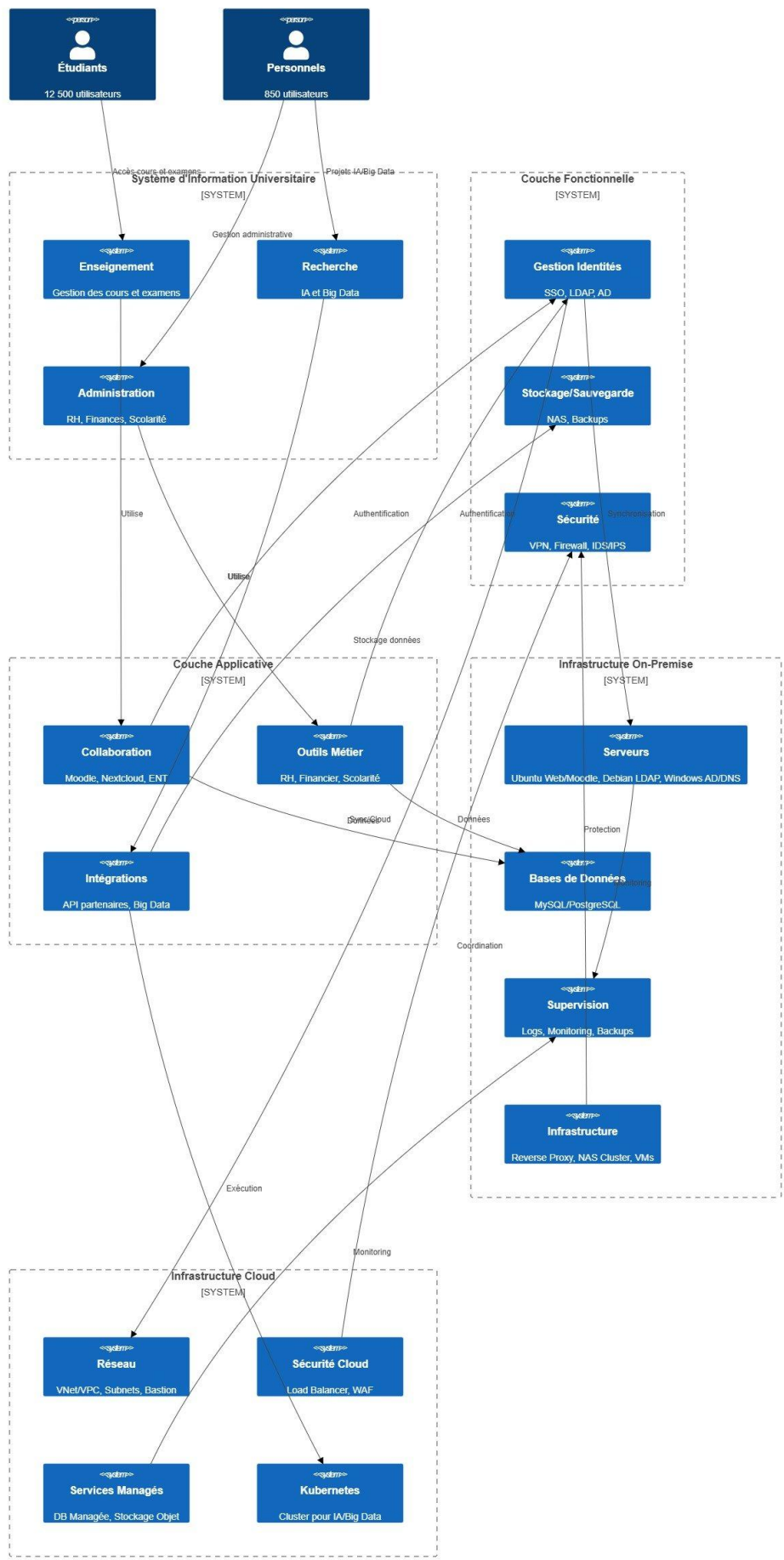
Le SI de l'Université F s'articule autour de deux environnements complémentaires :

Infrastructure On-Premise	Infrastructure Cloud
Datacenter interne avec serveurs physiques et virtualisés	Cloud public (Azure/AWS) pour services exposés et recherche
Serveurs Ubuntu, Debian, Windows Server, BDD MySQL/PostgreSQL	VNet/VPC segmenté, Load Balancer, WAF, Kubernetes managé
NAS, serveur de sauvegarde, reverse proxy, supervision	Stockage objet, BDD managée, environnement pédagogique cloud
~300 postes utilisateurs (étudiants, enseignants, administratifs)	Interconnexion sécurisée via VPN site-to-site (IPSec/IKEv2 AES-256)

2. Cartographie Complète du Système d'Information

L'ensemble des diagrammes suivants a été réalisé sous draw.io. Chaque diagramme est accompagné d'une fiche explicative.

2.0 Vue Globale de l'Architecture SI



Fiche explicative

Ce diagramme constitue la vue synthétique de l'ensemble du SI. Il présente les acteurs principaux (12 500 étudiants, 850 personnels) et leurs interactions avec les quatre grandes couches du SI : Système d'Information Universitaire, Couche Fonctionnelle, Couche Applicative et Infrastructures (On-Premise et Cloud). Il met en évidence les flux d'authentification, les dépendances inter-couches et la coexistence de l'environnement local avec l'environnement cloud.

2.1 Diagramme d'Urbanisation du SI

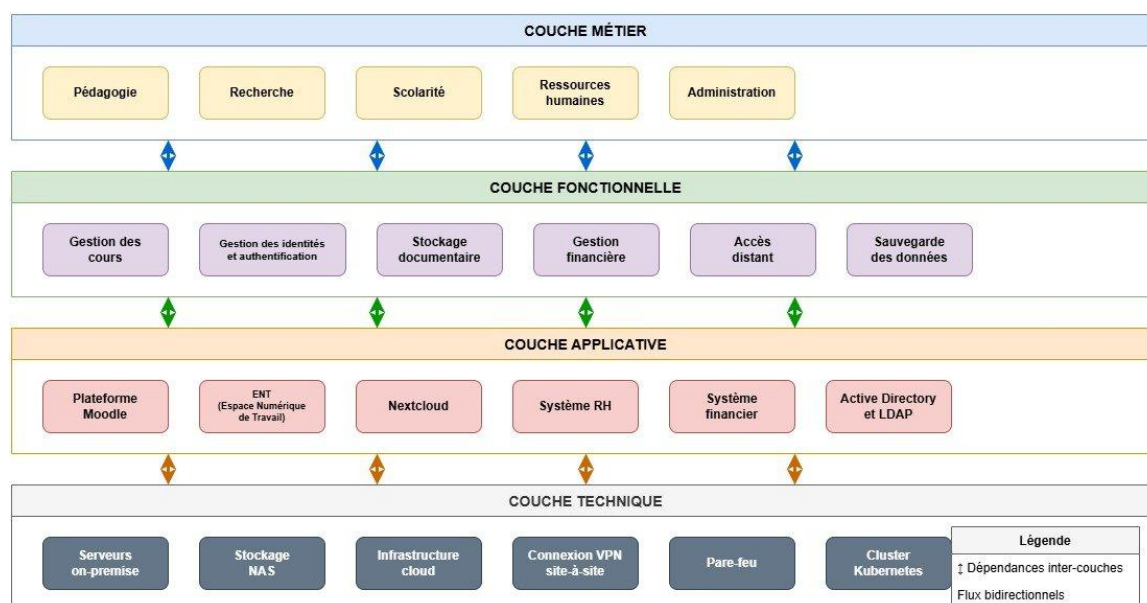


Figure 1 — Diagramme d'urbanisation (couches métier / fonctionnelle / applicative / technique)

Fiche explicative

Le diagramme d'urbanisation représente le SI sous forme de couches empilées selon le modèle classique d'architecture d'entreprise :

- Couche Métier : les domaines fonctionnels de l'université — Pédagogie, Recherche, Scolarité, Ressources Humaines, Administration
- Couche Fonctionnelle : les fonctions informatiques transverses — Gestion des cours, Gestion des identités/authentification, Stockage documentaire, Gestion financière, Accès distant, Sauvegarde des données
- Couche Applicative : les applications qui implémentent ces fonctions — Moodle, ENT, Nextcloud, Système RH, Système financier, Active Directory/LDAP
- Couche Technique : les composants d'infrastructure — Serveurs on-premise, Stockage NAS, Infrastructure cloud, VPN site-à-site, Pare-feu, Cluster Kubernetes

Les flèches bidirectionnelles entre couches illustrent les dépendances inter-couches et les flux d'information.

2.2 Diagramme d'Architecture Technique Hybride

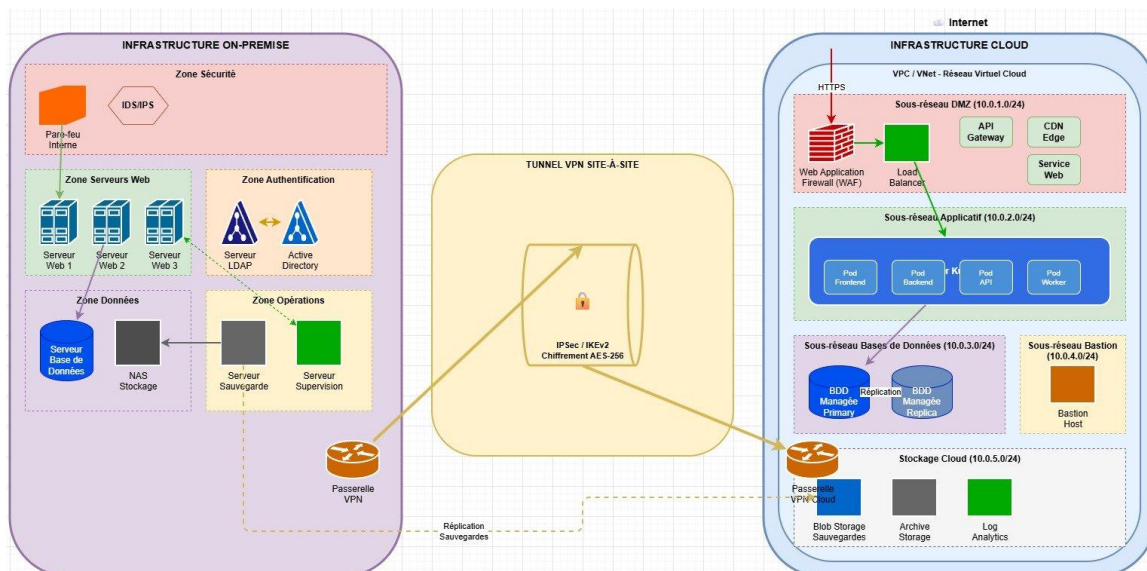


Figure 2 — Architecture technique hybride (On-Premise + Cloud)

Fiche explicative

Ce diagramme détaille l'architecture technique des deux environnements interconnectés :

- Infrastructure On-Premise : organisée en zones fonctionnelles (Zone Sécurité avec Pare-feu et IDS/IPS, Zone Serveurs Web, Zone Authentification avec LDAP et Active Directory, Zone Données avec BDD et NAS, Zone Opérations avec serveurs de sauvegarde et supervision). La connectivité externe est assurée via une Passerelle VPN.
- Tunnel VPN Site-à-Site : protocole IPsec/IKEv2 avec chiffrement AES-256 garantissant la confidentialité et l'intégrité des communications inter-sites.
- Infrastructure Cloud : organisée en sous-réseaux segmentés — DMZ (10.0.1.0/24) avec WAF et Load Balancer, Sous-réseau Applicatif (10.0.2.0/24) avec cluster Kubernetes (pods frontend, backend, API, worker), Sous-réseau BDD (10.0.3.0/24) avec réplication Primary/Replica, Sous-réseau Bastion (10.0.4.0/24), Stockage Cloud (10.0.5.0/24) avec Blob Storage, Archive et Log Analytics.

2.3 Diagramme des Zones de Sécurité

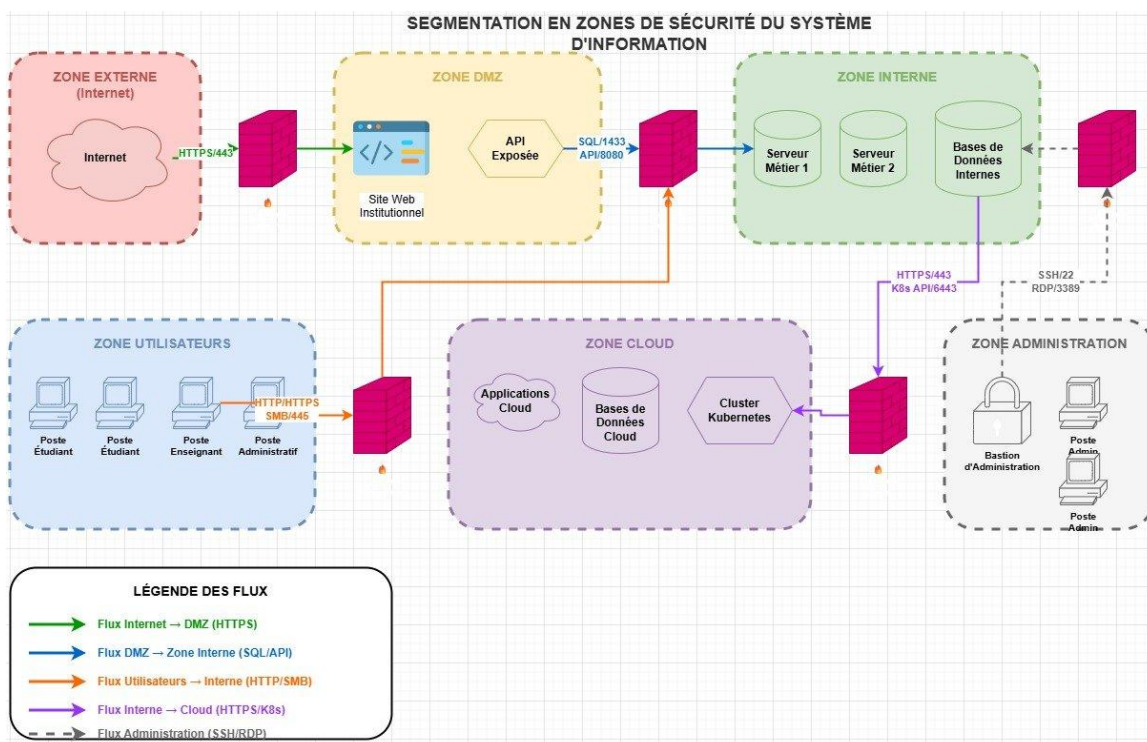


Figure 3 — Segmentation en zones de sécurité du SI

Fiche explicative

Ce diagramme représente la segmentation du SI en 6 zones de sécurité distinctes, chacune avec son niveau de confiance et ses règles de filtrage :

- Zone Externe (Internet) : zone non fiable, source de toutes les menaces externes. Les flux entrants sont limités au protocole HTTPS/443.
- Zone DMZ : zone tampon hébergeant le site web institutionnel et les API exposées. Accessible depuis Internet en HTTPS, elle communique avec la Zone Interne via SQL/1433 et API/8080.
- Zone Interne : cœur du SI hébergeant les serveurs métier et les bases de données internes. Accessible uniquement depuis la DMZ et la Zone Administration.
- Zone Utilisateurs : regroupe les postes étudiants, enseignants et administratifs. Les flux sortants vers la Zone Cloud sont filtrés (HTTP/HTTPS, SMB/445).
- Zone Cloud : héberge les applications cloud, bases de données cloud et cluster Kubernetes. Communique avec la Zone Interne via HTTPS/443 et K8s API/6443.
- Zone Administration : zone hautement sécurisée regroupant le bastion d'administration et les postes admin. Accès via SSH/22 et RDP/3389 strictement contrôlés.

2.4 Cartographie Applicative

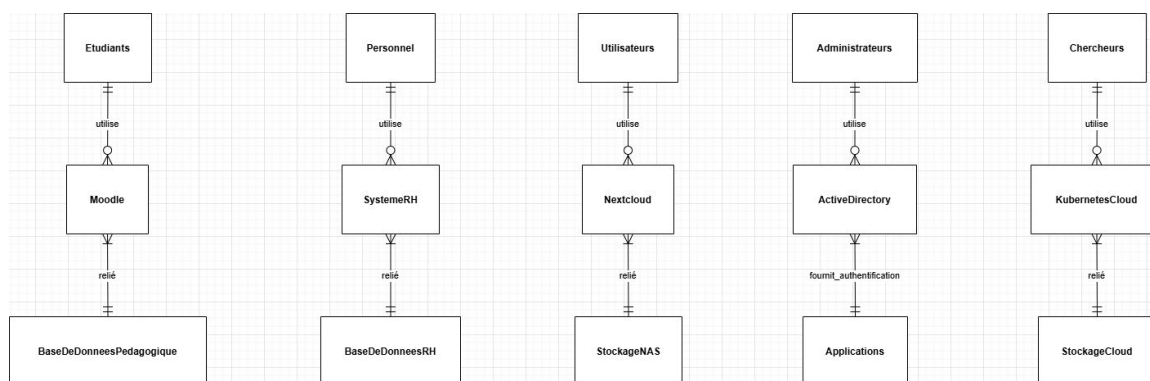


Figure 4 — Cartographie applicative du SI

Fiche explicative

La cartographie applicative présente les relations entre les acteurs, les applications et les données au sein du SI :

- Étudiants → Moodle → BaseDeDonneesPdagogique : les étudiants accèdent à la plateforme pédagogique qui s'appuie sur une base de données dédiée.
- Personnel → SystèmeRH → BaseDeDonneesRH : le personnel utilise le système RH connecté à sa base de données.
- Utilisateurs → Nextcloud → StockageNAS : tous les utilisateurs accèdent au stockage documentaire via Nextcloud, adossé au NAS.
- Administrateurs → ActiveDirectory → Applications : l'Active Directory fournit l'authentification centralisée pour toutes les applications.
- Chercheurs → KubernetesCloud → StockageCloud : les chercheurs utilisent le cluster Kubernetes pour leurs projets IA/Big Data.

2.5 Cartographie des Processus Métier



Figure 5 — Cartographie des processus métier

Fiche explicative

La cartographie des processus métier représente trois flux transversaux principaux du SI universitaire :

- Sauvegarde des données : flux Serveurs applicatifs → NAS → Stockage cloud de sauvegarde. Ce processus garantit la résilience des données critiques par une stratégie de sauvegarde en deux niveaux (NAS local puis externalisation cloud).
- Gestion des ressources humaines : flux Système RH → Base de données RH → Outils de reporting. Ce processus couvre l'ensemble du cycle de vie RH (recrutement, paie, congés) avec production de tableaux de bord.
- Inscription et accès aux cours : flux SI de scolarité → ENT → Moodle → Base de données pédagogique. Ce processus critique (surtout en période d'examens) assure l'inscription des étudiants et leur accès aux ressources pédagogiques.

2.6 Diagramme des Flux de Données

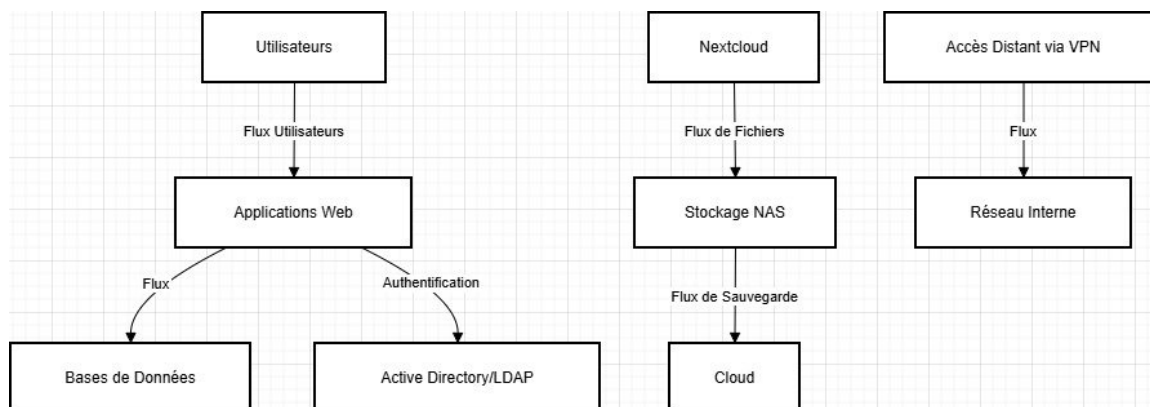


Figure 6 — Diagramme des flux de données

Fiche explicative

Le diagramme des flux de données illustre les échanges d'information entre les principaux composants du SI :

- Flux Utilisateurs → Applications Web → Bases de Données : flux principal des utilisateurs vers les applications web, qui s'appuient sur les bases de données back-end.
- Authentification → Active Directory/LDAP : toutes les applications web délèguent l'authentification à l'annuaire centralisé (AD/LDAP).
- Nextcloud → Stockage NAS : les fichiers partagés via Nextcloud sont physiquement stockés sur le NAS interne.
- Flux de Sauvegarde NAS → Cloud : réplication périodique des données du NAS vers le stockage cloud pour externalisation des sauvegardes.
- Accès Distant via VPN → Réseau Interne : les accès distants des enseignants et personnels transitent par le VPN pour rejoindre le réseau interne.

3. Analyse des Incidents de Sécurité

L'analyse porte sur 8 des 12 incidents recensés, sélectionnés pour leur représentativité et leur impact.

Incident 1 — Attaque par Phishing (Compromission Comptes Enseignants)

Cause probable	Absence de sensibilisation des enseignants aux techniques de phishing. Emails frauduleux imitant des communications officielles (administration universitaire, éditeurs logiciels). Absence de filtrage anti-phishing au niveau du serveur de messagerie.
Impact potentiel	Compromission des comptes enseignants donnant accès à Moodle, Nextcloud, ressources pédagogiques et potentiellement aux données étudiants. Risque de propagation latérale vers d'autres systèmes si SSO mal cloisonné.
Vulnérabilité sous-jacente	Absence de MFA (Multi-Factor Authentication) sur les comptes enseignants. Politique de mot de passe insuffisante. Absence de formation à la cybersécurité.
Mesure corrective	Déploiement du MFA obligatoire pour tous les comptes enseignants et personnels. Mise en place de filtres anti-phishing (SPF, DKIM, DMARC) sur la messagerie. Programme de sensibilisation annuel avec simulations de phishing.

Incident 2 — Fuite de Données via Mauvaise Configuration Nextcloud

Cause probable	Mauvaise configuration des droits de partage sur Nextcloud : dossiers ou fichiers partagés publiquement sans authentification requise. Absence de revue périodique des permissions de partage.
Impact potentiel	Exposition de données sensibles (données RH, documents administratifs, données personnelles étudiants). Violation du RGPD avec obligation de notification à la CNIL. Atteinte à la réputation de l'université.
Vulnérabilité sous-jacente	Absence de politique de classification des données. Absence de contrôle des partages publics. Utilisateurs non formés aux bonnes pratiques de partage.
Mesure corrective	Audit des partages Nextcloud existants et révocation des partages non justifiés. Désactivation des liens de partage public par défaut. Mise en place d'une politique de classification et de gestion des données. Alertes automatiques sur les partages publics.

Incident 3 — Ransomware sur Poste Administratif avec Propagation Réseau

Cause probable	Infection initiale probablement via pièce jointe malveillante (phishing) ou navigation sur site compromis. La propagation vers les lecteurs réseau indique une absence de segmentation des droits d'accès aux partages réseau.
Impact potentiel	Chiffrement et perte de données administratives critiques (RH, finances, scolarité). Indisponibilité prolongée des services. Coût de restauration élevé. Potentielle demande de rançon. Impact sur la continuité de service.
Vulnérabilité sous-jacente	Principe du moindre privilège non appliqué : les postes administratifs ont des droits d'écriture excessifs sur les partages réseau. Absence de solution EDR (Endpoint Detection and Response). Sauvegardes potentiellement accessibles depuis les postes compromis.
Mesure corrective	Application stricte du principe du moindre privilège sur les partages réseau. Déploiement d'une solution EDR sur les postes. Isolation des sauvegardes (immuables, hors ligne). Segmentation réseau renforcée pour limiter la propagation latérale.

Incident 4 — Injection SQL sur la Plateforme Pédagogique (Moodle)

Cause probable	Champ de formulaire (recherche, forum, dépôt de devoir) non correctement filtré côté serveur. Version de Moodle potentiellement non patchée présentant une vulnérabilité connue. Absence de WAF en protection de la plateforme.
Impact potentiel	Exfiltration de la base de données pédagogique (données personnelles étudiants, notes, contenus de cours). Modification ou suppression de données. Contournement de l'authentification. Violation RGPD.
Vulnérabilité sous-jacente	Absence de validation et sanitisation des entrées utilisateur. Requêtes SQL non paramétrées. Compte de base de données avec des privilèges excessifs. Absence de WAF.
Mesure corrective	Mise à jour immédiate de Moodle vers la dernière version stable. Déploiement d'un WAF en frontal de la plateforme. Audit de code des développements spécifiques. Application du principe de moindre privilège sur les comptes de base de données.

Incident 5 — Mauvaise Gestion IAM Cloud (Rôle Admin Attribué à un Étudiant)

Cause probable	Erreur humaine lors de la configuration des rôles IAM sur l'environnement cloud pédagogique. Absence de processus de validation des attributions de rôles. Confusion entre compte étudiant et compte administrateur dans l'annuaire.
Impact potentiel	Accès non autorisé à l'ensemble de l'infrastructure cloud : bases de données, stockage, configurations réseau. Possible exfiltration, modification ou suppression de ressources. Coûts cloud non maîtrisés si l'étudiant provisionne des ressources.
Vulnérabilité sous-jacente	Absence de processus IAM formalisé (RBAC mal configuré). Pas de revue périodique des droits. Pas d'alertes sur les attributions de rôles à privilèges élevés.
Mesure corrective	Mise en place d'un processus formel d'attribution des droits cloud avec double validation. Revue trimestrielle des droits IAM. Activation des alertes CloudTrail/Azure Monitor sur les changements de rôles. Application stricte du principe du moindre privilège (RBAC).

Incident 6 — Exposition Publique Accidentelle d'une Base de Données Cloud

Cause probable	Mauvaise configuration des Network Security Groups (NSG) ou règles de pare-feu cloud laissant le port de la BDD (3306/5432) accessible depuis Internet. Absence de revue des configurations réseau cloud.
Impact potentiel	Exposition directe de la base de données à des attaques par force brute, injection SQL ou exploitation de vulnérabilités du SGBD. Exfiltration de toutes les données stockées. Violation RGPD avec sanctions potentielles.
Vulnérabilité sous-jacente	Absence de politique de sécurité réseau cloud formalisée. Pas d'outil de détection des misconfiguration cloud (CSPM). Absence de scan régulier des surfaces d'exposition.
Mesure corrective	Déploiement d'un outil CSPM (Cloud Security Posture Management). Règle de sécurité : aucun port de BDD n'est accessible depuis Internet. Scan automatisé des configurations cloud. Mise en place d'alertes sur les ouvertures de ports vers Internet.

Incident 7 — Compromission d'un Compte VPN sans MFA

Cause probable	Mot de passe du compte VPN compromis (via phishing, réutilisation de mot de passe ou brute force). Absence de MFA permettant l'accès avec les seules credentials volées.
Impact potentiel	Accès non autorisé au réseau interne de l'université depuis Internet. Possibilité de mouvement latéral vers les serveurs, NAS et BDD internes. Exfiltration de données, installation de backdoors.
Vulnérabilité sous-jacente	MFA non obligatoire sur les accès VPN. Absence de détection des connexions VPN depuis des géolocalisations inhabituelles. Politique de mots de passe insuffisante.

Mesure corrective	MFA obligatoire pour tous les accès VPN. Détection des anomalies de connexion (géolocalisation, horaires inhabituels). Limitation des plages IP autorisées à se connecter en VPN. Rotation régulière des certificats VPN.
--------------------------	---

Incident 8 — Attaque DDoS sur le Site Institutionnel

Cause probable	Attaque par déni de service distribué ciblant le site web institutionnel hébergé dans la DMZ cloud. Le volume de trafic malveillant a saturé les ressources du serveur ou du Load Balancer.
Impact potentiel	Indisponibilité du site institutionnel (image de l'université). Impact sur les candidatures, informations aux étudiants et partenaires. Potentiel effet de rebond sur d'autres services si l'infrastructure est partagée.
Vulnérabilité sous-jacente	Absence de protection anti-DDoS dédiée (CDN, scrubbing center). WAF présent mais non configuré pour l'atténuation DDoS. Absence de plan de réponse DDoS formalisé.
Mesure corrective	Souscription à un service de protection DDoS (Cloudflare, Azure DDoS Protection). Déploiement d'un CDN pour absorber le trafic légitime. Mise en place d'un rate limiting sur le WAF. Plan de réponse aux incidents DDoS documenté.

4. Analyse des Risques

L'analyse des risques suit la méthodologie EBIOS RM. Chaque risque est évalué selon trois niveaux : Faible (F), Moyen (M) et Élevé (E). La priorité est définie par la combinaison Probabilité × Impact.

#	Description du risque	Actif concerné	Probabilité	Impact	Priorité	Justification
1	Compromission des comptes utilisateurs par phishing ou brute force	SSO/LDAP/AD, Moodle, ENT	Élevée	Élevé	CRITIQUE	Incident phishing avéré, MFA absent, 12 500+ comptes
2	Attaque ransomware avec propagation vers partages réseau	NAS, serveurs de fichiers, BDD	Élevée	Critique	CRITIQUE	Incident avéré, droits excessifs sur partages, EDR absent
3	Exposition ou fuite de données personnelles (RGPD)	BDD étudiants, Nextcloud, RH	Élevée	Élevé	CRITIQUE	Incidents Nextcloud et BDD cloud avérés
4	Injection SQL sur applications web (Moodle, portail)	Moodle, BDD pédagogique, portail étudiant	Élevée	Élevé	CRITIQUE	Incident avéré, plateforme exposée sur Internet
5	Accès non autorisé via VPN compromis (absence de MFA)	Réseau interne, serveurs, NAS	Élevée	Élevé	CRITIQUE	Incident VPN sans MFA avéré
6	Indisponibilité de la plateforme pédagogique en période d'examens	Moodle, ENT, réseau	Moyenne	Critique	ÉLEVÉE	Incident de 6h avéré, impact fort sur 12 500 étudiants
7	Mauvaise gestion des droits IAM cloud (sur-privileges)	Infrastructure cloud, BDD managée, Kubernetes	Élevée	Élevé	ÉLEVÉE	Incident IAM avéré (rôle admin attribué à étudiant)
8	Attaque DDoS sur le site institutionnel	Site web, Load Balancer, WAF	Élevée	Moyen	ÉLEVÉE	Incident avéré, pas de protection DDoS dédiée
9	Usurpation ARP et attaque man-in-the-middle sur VLAN étudiant	VLAN Étudiants, commutateurs réseau	Élevée	Moyen	ÉLEVÉE	Suspicion avérée, population étudiante large, risque de sniffing
10	Infection par clé USB (menace interne)	Postes utilisateurs, réseau interne	Moyenne	Élevé	ÉLEVÉE	Incident avéré, vecteur interne difficile à contrôler
11	Compromission du serveur LDAP/Active Directory	LDAP, AD, ensemble du SI	Faible	Critique	ÉLEVÉE	Actif critique (Single Point of Failure pour l'authentification)
12	Vulnérabilités non patchées sur serveurs (Ubuntu, Debian, Windows)	Serveurs Ubuntu/Debian, Windows Server	Moyenne	Élevé	MOYENNE	Hétérogénéité OS, risque de patch management insuffisant

5. Recommandations Stratégiques

5.1 Recommandations Organisationnelles

R.ORG.1 — Formalisation d'une Politique de Sécurité du Système d'Information (PSSI)

L'Université F ne dispose pas d'une PSSI formalisée couvrant l'ensemble des domaines de sécurité. La mise en place de ce document fondateur est une priorité.

Actions concrètes :

- Rédiger et valider une PSSI couvrant : classification des données, gestion des accès, politique de mots de passe, gestion des incidents, continuité d'activité, télétravail et BYOD.
- Désigner un Responsable de la Sécurité des Systèmes d'Information (RSSI) avec mandat et budget dédiés.
- Intégrer la PSSI dans les contrats de travail et conventions d'utilisation du SI signés par chaque étudiant et personnel.
- Mettre en place un processus de révision annuelle de la PSSI et d'audit interne.
- Adopter une démarche de conformité ISO 27001 comme cadre de référence à moyen terme.

R.ORG.2 — Programme de Sensibilisation et de Formation à la Cybersécurité

Le facteur humain est à l'origine de la majorité des incidents recensés (phishing, clé USB, mauvaise configuration). Un programme structuré de sensibilisation est indispensable.

Actions concrètes :

- Déployer une formation obligatoire de sensibilisation à la cybersécurité pour tout le personnel et les étudiants en début d'année (modules e-learning de 30 minutes).
- Organiser des campagnes de phishing simulé trimestrielles avec retour pédagogique immédiat.
- Former les équipes IT aux bonnes pratiques cloud (IAM, configuration des NSG, principe du moindre privilège).
- Créer une charte informatique claire, signée à l'entrée, avec rappel des bonnes pratiques (mots de passe, partage de fichiers, clés USB).
- Publier un canal de signalement d'incidents simple et accessible pour tous les utilisateurs.

5.2 Recommandations Techniques

R.TECH.1 — Déploiement Généralisé du MFA et Renforcement de la Gestion des Identités

L'absence de MFA est la vulnérabilité technique la plus exploitée (phishing, VPN). C'est la mesure corrective à effet le plus immédiat.

Actions concrètes :

- Déployer le MFA obligatoire pour tous les accès : VPN, SSO/CAS, interfaces d'administration, cloud (Azure/AWS), Nextcloud.
- Intégrer une solution Zero Trust Network Access (ZTNA) pour les accès distants, en remplacement ou en complément du VPN traditionnel.
- Mettre en place un système PAM (Privileged Access Management) pour les comptes administrateurs.
- Automatiser le provisioning/déprovisioning des comptes (départs, changements de rôle) via synchronisation AD/LDAP.
- Activer la surveillance des connexions anormales (UEBA) : connexions depuis géolocalisations inhabituelles, heures atypiques, accès multiples simultanés.

R.TECH.2 — Renforcement de la Sécurité Applicative et de la Posture Cloud

Les incidents d'injection SQL et d'exposition cloud révèlent des lacunes dans la sécurité applicative et la gestion des configurations cloud.

Actions concrètes :

- Déployer un WAF correctement configuré en frontal de toutes les applications web exposées (Moodle, portail, API partenaires) avec règles OWASP Top 10.
- Mettre en place un cycle de patch management mensuel avec inventaire des vulnérabilités (outil de scan : OpenVAS, Qualys ou Tenable).
- Déployer un outil CSPM (Cloud Security Posture Management) pour détecter en continu les misconfiguration cloud (AWS Security Hub, Azure Defender for Cloud).
- Intégrer un SIEM (Security Information and Event Management) centralisant les logs de tous les équipements pour corrélation et détection d'incidents.
- Réaliser un audit de sécurité applicatif annuel (pentest) sur les applications critiques exposées sur Internet.

5.3 Recommandation de Sensibilisation

R.SENS.1 — Dispositif de Cyber-Résilience Culturelle

Au-delà des formations ponctuelles, l'objectif est d'ancrer une culture de la cybersécurité durable au sein de l'université.

Actions concrètes :

- Créer un "Security Champions" program : identifier et former des référents sécurité dans chaque département (enseignants, personnel admin) chargés de relayer les bonnes pratiques.
- Organiser annuellement un "Cybermois" avec ateliers pratiques, jeux sérieux (CTF étudiant) et interventions d'experts externes.
- Mettre en place un tableau de bord de la maturité sécurité accessible à la direction, montrant l'évolution des indicateurs clés (taux de MFA activé, incidents déclarés, postes patchés).
- Intégrer un module cybersécurité obligatoire dans les cursus de toutes les filières (pas seulement informatique), adapté aux besoins de chaque profil d'utilisateur.

6. Synthèse et Hiérarchisation des Priorités

Sur la base de l'analyse des incidents et des risques, voici la hiérarchisation des actions de sécurisation recommandées :

Priorité	Délai	Action	Justification
P1	< 1 mois	Déploiement MFA sur VPN, SSO et interfaces d'administration	Incidents VPN et phishing avérés, vecteur d'attaque principal
P1	< 1 mois	Audit et révocation des partages publics Nextcloud et droits IAM cloud excessifs	Fuites de données avérées, risque RGPD immédiat
P2	< 3 mois	Déploiement WAF et patch management Moodle/serveurs	Injection SQL avérée, surfaces d'attaque web importantes
P2	< 3 mois	Déploiement EDR sur postes administratifs et serveurs critiques	Ransomware avéré, propagation non détectée à temps
P2	< 3 mois	Déploiement outil CSPM et SIEM	Misconfigurations cloud répétées, besoin de visibilité centralisée
P3	< 6 mois	Programme de sensibilisation et formation cybersécurité	Facteur humain dominant dans les incidents, population à risque élevée
P3	< 6 mois	Rédaction et déploiement de la PSSI	Absence de cadre formalisé, prérequis à toute démarche structurée
P3	< 12 mois	Protection DDoS dédiée (CDN + Azure DDoS / Cloudflare)	Attaque DDoS avérée, dépendance croissante au cloud

Conclusion

L'Université F présente un niveau de maturité sécurité insuffisant au regard de la sensibilité des données traitées et du nombre d'incidents avérés. Les vulnérabilités identifiées sont majoritairement connues et corrigibles avec des solutions éprouvées. La priorité absolue réside dans le déploiement du MFA et la correction des misconfiguration cloud, qui représentent le rapport coût/efficacité le plus favorable. À moyen terme, la mise en place d'une PSSI et d'un programme de sensibilisation permettra d'ancrer une culture de la sécurité durable, seule garantie d'une amélioration pérenne du niveau de protection du SI.

Document rédigé dans le cadre du Mini-projet d'Audit SI — ESAIP École d'Ingénieurs — IR, MSC